RoundFi Risks, Regulation and Compliance Considerations

Table of Contents

RoundFi Risks, Regulation and Compliance Considerations

Document ID: 09-risk-and-compliance
Project: RoundFi
Version: 1.0
Date: May 2026
Status: Hackathon-stage risk framework
Repository path: docs/en/09-risk-and-compliance.md

Executive Summary

RoundFi is an on-chain behavioral credit protocol built on Solana. It uses recurring payment participation to generate portable behavioral reputation and progressively reduce collateral requirements in DeFi.

This document explains the main legal, regulatory, compliance, technical, economic, and adoption risks around RoundFi, as well as the mitigation strategy for each one.

The goal is not to claim that all risks are solved today. The goal is to show that RoundFi understands the risk surface and is designing the protocol in a way that can move from hackathon prototype to compliant mainnet product.

The most important framing is:

> RoundFi is currently a hackathon-stage protocol prototype on Solana Devnet. It is not yet a fully audited mainnet credit product, regulated financial institution, VASP, broker, lender, credit bureau, or investment product.

RoundFi's current scope is technical validation:

- functional prototype;
- Solana Devnet deployment;
- Stress Lab simulations;
- open-source repository;
- app-to-chain proof paths;
- architecture for behavioral reputation;
- roadmap toward external audit, production indexer, SAS integration, and B2B reputation oracle.

Regulation, compliance, audit, risk controls, and partner validation are core requirements before any mainnet or real-credit deployment.

---

1. Risk Philosophy

RoundFi is ambitious, but the project should avoid empty confidence.

The correct risk posture is:

- do not deny regulatory complexity;
- do not claim legal approval;
- do not promise guaranteed credit;
- do not claim the protocol never fails;
- do not present modeled solvency as real-world certainty;
- do not market the protocol as risk-free yield;
- do not treat Devnet proof as production readiness.

Instead, RoundFi should communicate:

- what is already shipped;
- what is still roadmap;
- what needs external validation;
- what risks are known;
- how each risk is being reduced.

This is especially important for Colosseum, investors, auditors, partners, and ecosystem teams. Technical judges are more likely to trust a team that explains risk clearly than a team that hides it.

---

2. Current Scope vs. Future Scope

2.1 Current Scope

RoundFi is currently focused on hackathon-stage validation.

Current scope includes:

- functional prototype;
- Solana Devnet deployment;
- open-source codebase;
- Stress Lab simulations;
- on-chain program architecture;
- app-to-chain transaction flows;
- internal security review;

- documentation of shipped, under-verification, and roadmap items.

2.2 Future Scope

Future scope includes:

- external audit;
- mainnet beta;
- production indexer;
- official SAS issuance path;
- B2B reputation oracle API;
- protocol partnerships;
- compliance review;
- jurisdiction strategy;
- possible KYC/AML or proof-of-personhood integrations depending on product scope.

2.3 Why This Distinction Matters

Many crypto projects lose credibility because they present roadmap items as shipped product.

RoundFi should do the opposite.

Every document, pitch, and repository page should clearly separate:

1. **Shipped / Demoable Today**
2. **Implemented / Under Verification**
3. **Roadmap / Mainnet Scope**

This reduces legal, technical, and reputational risk.

---

3. Regulatory Risk Overview

RoundFi touches sensitive categories:

- credit;
- savings groups;
- DeFi lending;
- reputation data;
- attestations;
- collateral reduction;
- yield infrastructure;
- possible future B2B scoring.

These categories may be regulated differently depending on jurisdiction and product implementation.

The core regulatory question is not simply:

Is RoundFi decentralized?

The real questions are:

- Is any party custodying user funds?
- Is any party arranging credit?
- Is any instrument offered to the public?
- Is any yield or profit expectation marketed?
- Are users buying positions that represent claims on future cash flows?
- Is reputation data being processed as personal data?
- Is the protocol operating as a VASP, lender, credit bureau, broker, exchange, or investment product?
- Is the product aimed at retail users, institutions, or protocols?
- Are users located in jurisdictions with specific licensing rules?

RoundFi should treat regulation as a design constraint, not an afterthought.

---

4. Risk: Being Treated as a Regulated Credit or Lending Product

Description

RoundFi's long-term thesis involves reducing collateral requirements for credit. Any product that enables access to credit may trigger licensing, consumer protection, usury, disclosure, lending, or financial intermediation rules depending on jurisdiction.

Even if the protocol is non-custodial, regulators may analyze the substance of the activity rather than only the technical architecture.

Why It Matters

RoundFi should avoid presenting itself as a fully operational lending business before the appropriate legal structure, licensing analysis, consumer disclosures, and partner framework are in place.

Mitigation Strategy

- Frame current scope as protocol research, prototype, and Devnet validation.
- Avoid promising guaranteed loans or credit approval.
- Separate the reputation protocol from any lending decision.
- Let partner protocols decide whether and how they use the score.
- Use clear risk disclosures.
- Obtain jurisdiction-specific legal counsel before mainnet or real-credit launch.
- Start with pilots where the counterparty already has the necessary licensing or regulatory perimeter.

Recommended Public Framing

Use:

> RoundFi generates behavioral reputation that can help protocols evaluate collateral requirements.

Avoid:

> RoundFi gives loans to unbanked users.

---

5. Risk: Being Treated as a Consortium / ROSCA / Financial Pool Operator

Description

RoundFi uses savings groups as a behavioral data engine. This is structurally related to ROSCAs and group-based savings behavior. In some jurisdictions, organized savings groups, pooled funds, or rotating credit systems may fall under financial regulation.

In Brazil, the formal consortium market is heavily regulated. RoundFi should not casually describe itself as a Brazilian consortium product unless that is a deliberate legal strategy.

Why It Matters

The consortium analogy is useful to explain behavior, but risky as the legal category for the product.

RoundFi is stronger when it positions savings groups as:

> a mechanism for generating behavioral reputation

not as:

> the final regulated financial product.

Mitigation Strategy

- Use “savings groups” or “recurring contribution groups” for explanation.
- Avoid claiming to operate regulated consórcios.
- Clarify that the group is the mechanism, not the product.
- Keep the core product as portable behavioral reputation.
- Use legal counsel before launching any jurisdiction-specific cash-flow pooling product.
- Consider protocol partnerships where licensed entities operate the regulated front-end.

Recommended Public Framing

Use:

> RoundFi uses group-based recurring contributions to generate verifiable financial behavior.

Avoid:

> RoundFi is a Web3 consortium.

---

6. Risk: Securities or Investment Product Classification

Description

Certain tokens, NFTs, positions, yield-bearing arrangements, or claims on future payouts could potentially be analyzed as securities or collective investment contracts depending on their design, marketing, transferability, revenue expectations, and reliance on the efforts of others.

This risk is especially relevant if:

- a position NFT represents a claim on future cash flows;
- users expect profit from protocol-managed yield;
- a secondary market position is marketed as an investment;
- liquidity providers receive returns from pooled activity;
- the protocol promotes future upside rather than utility.

Why It Matters

Crypto lending and yield products have already faced enforcement action. The SEC's BlockFi settlement is a relevant warning for crypto lending products marketed with interest or yield expectations.

Mitigation Strategy

- Avoid investment-return marketing.
- Avoid "risk-free yield" language.
- Treat yield as auxiliary, not the core product.
- Make the primary utility explicit: behavioral reputation and collateral efficiency.
- Review position NFT design with counsel.
- Consider transfer restrictions or compliance gating if future versions create regulated claims.
- Maintain clear public disclosures about devnet, prototype scope, and risk.

Recommended Public Framing

Use:

> Yield infrastructure is an auxiliary mechanism for capital efficiency.

Avoid:

> Users invest in RoundFi positions to earn yield.

---

7. Risk: VASP / AML / Travel Rule Exposure

Description

Virtual Asset Service Provider rules may apply when a business exchanges, transfers, safekeeps, administers, or facilitates virtual assets for users. The exact analysis depends on jurisdiction and operational control.

RoundFi's current architecture is a protocol prototype, but future versions involving front-end operation, custody, user onboarding, stablecoin flows, or partner APIs may enter VASP or AML territory.

Why It Matters

FATF standards and local VASP rules increasingly require AML/CFT controls, suspicious activity monitoring, customer due diligence, sanctions screening, and travel-rule compliance for certain virtual asset businesses.

Brazil's Law 14.478/2022 created a legal framework for virtual asset service providers and establishes that VASPs may require prior authorization from the competent public authority.

Mitigation Strategy

- Keep current hackathon version wallet-only and non-custodial.
- Do not market current version as a regulated exchange, broker, custodian, or payment institution.
- Add KYC/AML only when the operating model requires it.
- Partner with regulated institutions for fiat rails or credit issuance.
- Design modular compliance hooks: identity provider, risk scoring, sanctions, and reporting.
- Document what is protocol logic vs. operator responsibility.

Recommended Public Framing

Use:

> Identity and compliance layers are modular and jurisdiction-dependent.

Avoid:

> No regulation applies because it is on-chain.

---

8. Risk: Data Privacy and On-Chain Reputation

Description

RoundFi's long-term product is behavioral reputation. That means the protocol creates, stores, and exposes information about financial behavior.

Even if the data is pseudonymous, wallet-linked behavior may still be considered personal data if it can be associated with an identifiable person.

Under GDPR, pseudonymised data can still be personal data if it can be used to re-identify an individual. Brazil's LGPD also regulates the processing of personal data by private and public entities.

Why It Matters

On-chain data is difficult or impossible to delete. This creates tension with privacy rights, data minimization, retention limits, correction, and user control.

Mitigation Strategy

- Avoid putting personal data on-chain.
- Store only minimal attestations on-chain.
- Use schemas that encode behavior without exposing unnecessary personal details.
- Keep sensitive data off-chain with user consent and access controls.
- Consider revocation, expiration, or versioning of attestations.
- Design the B2B API around purpose limitation and data minimization.
- Add privacy and consent language before production launch.
- Separate wallet reputation from legal identity unless strictly necessary.

Recommended Public Framing

Use:

> RoundFi creates minimal behavioral attestations and avoids storing personal identity data on-chain.

Avoid:

> All payment behavior is public forever and reusable by anyone.

---

9. Risk: Reputation Gaming, Sybil Attacks, and Farming

Description

Any reputation system creates incentives for manipulation. Users may try to generate artificial history using multiple wallets, fake groups, circular payments, or coordinated farming.

Why It Matters

If RoundFi's reputation can be cheaply farmed, partner protocols will not trust it.

Mitigation Strategy

- Require real capital commitment over time.
- Weight recurring payment cycles more than isolated activity.
- Add cooldowns between meaningful score events.

- Use level progression based on completed cycles, not instant actions.
- Add optional proof-of-personhood or KYC for higher tiers if necessary.
- Penalize defaults and late payments heavily.
- Detect circular group patterns via indexer analytics.
- Require partner protocols to consume the score with risk-adjusted limits.

Recommended Public Framing

Use:

> Reputation is earned through repeated financial commitment over time.

Avoid:

> Anyone can instantly build reputation.

---

10. Risk: Partner Adoption of the Reputation Signal

Description

The long-term business model depends on protocols, fintechs, neobanks, or financial applications trusting and consuming RoundFi's reputation score.

This is not guaranteed.

A score has value only if third parties believe it improves underwriting or risk management.

Why It Matters

The B2B oracle is the high-margin endgame, but it is still roadmap. Without partner adoption, RoundFi remains mostly a protocol demo and savings group product.

Mitigation Strategy

- Produce clear score methodology documentation.
- Publish false-positive / false-negative risk analysis.
- Build dashboards for partner risk teams.
- Start with small controlled pilots.
- Target protocols already exploring undercollateralized or reputation-based credit.
- Provide API reliability, audit logs, and clear score explainability.
- Use conservative score recommendations at first.

Recommended Public Framing

Use:

> The B2B oracle is the long-term product layer and requires partner validation.

Avoid:

> Protocols will automatically use our score.

---

11. Risk: Smart Contract Security

Description

RoundFi handles financial state transitions: joining pools, contributing, claiming payouts, releasing escrow, defaults, yield routing, and secondary-market transfers.

Any bug in these flows can create loss of funds, incorrect accounting, stuck funds, invalid reputation, or exploit paths.

Why It Matters

Smart contract risk is existential for any DeFi protocol.

Current Controls

The repository documents:

- open-source architecture;
- Devnet deployment;
- internal security audit;
- test suite;
- Stress Lab;
- CI gates;
- Solscan-verifiable transactions;
- discovered and fixed devnet issue involving Metaplex Core plugin authorities.

Mitigation Strategy

- External audit before mainnet.
- Bug bounty before public funds.
- Conservative caps in early mainnet beta.
- Pause / emergency controls with transparent governance.
- Formal invariant tests for accounting and solvency logic.
- Bankrun and localnet testing across all default scenarios.
- Clear separation between mock adapters and production adapters.

Recommended Public Framing

Use:

> RoundFi is open-source, internally reviewed, and requires external audit before mainnet.

Avoid:

> RoundFi is secure because tests pass.

12. Risk: Economic Model and Stress Lab Limitations

Description

The Stress Lab is a powerful validation tool, but simulations are not the same as production behavior.

The model can test predefined scenarios, but cannot fully predict:

- real user behavior;
- black swan market events;
- liquidity shocks;
- protocol integrations failing;
- correlated defaults;
- attack behavior;
- governance failures;
- yield collapse;
- front-end or indexer failures.

Why It Matters

RoundFi should not imply that modeled solvency means guaranteed solvency in all real-world conditions.

Mitigation Strategy

- Use the phrase “solvent within modeled conditions.”
- Keep Stress Lab assumptions transparent.
- Publish scenario definitions.
- Compare L1 simulation to L2 on-chain behavior through parity tests.
- Add adversarial scenarios over time.
- Use caps and staged launch limits.
- Keep yield optional and auxiliary.

Recommended Public Framing

Use:

> The protocol remained solvent within modeled stress conditions.

Avoid:

> The protocol never breaks.

13. Risk: Yield Integration

Description

RoundFi can route idle capital through yield infrastructure. Yield can improve economics, but it introduces additional risk.

Risks include:

- APY volatility;
- smart contract risk in third-party protocols;
- liquidity withdrawal risk;
- integration bugs;
- slippage;
- adapter failures;
- incentive changes.

Why It Matters

If the protocol's economics depend too heavily on yield, a yield collapse could weaken the model.

Mitigation Strategy

- Treat yield as auxiliary, not foundational.
- Ensure the Stress Lab includes zero-yield scenarios.
- Use adapter-is-untrusted design.
- Validate balances before and after CPI calls.
- Support adapter replacement.
- Cap risk exposure in early deployments.
- Keep user-facing language conservative.

Recommended Public Framing

Use:

> Yield can improve capital efficiency, but RoundFi's core thesis does not depend on stable APYs.

Avoid:

> Yield guarantees protocol profitability.

---

14. Risk: SAS Dependency and Attestation Portability

Description

RoundFi's reputation thesis depends on attestations being readable, trusted, and portable across protocols.

If SAS adoption is slower than expected, if standards change, or if partner protocols do not consume the data, portability may be weaker than the thesis assumes.

Mitigation Strategy

- Keep the attestation layer modular.
- Use SAS-compatible schemas while avoiding hard dependency on a single provider.
- Maintain internal read paths and indexer support.
- Version schemas for future migrations.
- Publish developer documentation for consumers.
- Design APIs that can abstract away the underlying attestation layer.

Recommended Public Framing

Use:

> RoundFi is designed around portable attestations and can expose reputation through both on-chain reads and APIs.

Avoid:

> SAS automatically guarantees ecosystem-wide adoption.

---

15. Risk: Secondary Market and Position NFT Design

Description

RoundFi includes an Escape Valve mechanism where users may transfer/sell positions instead of defaulting.

This is useful, but can create legal and technical complexity if the NFT or position represents financial rights, future claims, or expected returns.

Why It Matters

Transferable financial positions may attract regulatory scrutiny depending on design and jurisdiction.

Mitigation Strategy

- Position NFTs should be described operationally, not as investment assets.
- Clarify that a position represents membership/state in a protocol, not guaranteed return.

- Use transfer restrictions if required by counsel.
- Avoid marketing secondary positions as yield or investment products.
- Keep Escape Valve as a risk-reduction mechanism, not a speculative marketplace.

Recommended Public Framing

Use:

> Escape Valve allows a user to exit without defaulting and protects the pool's accounting.

Avoid:

> Users can trade profitable credit positions.

---

16. Risk: Consumer Protection and User Understanding

Description

Credit, collateral, defaults, escrow, pooled payments, and reputation are complex. Users may misunderstand obligations, consequences, or risk.

Why It Matters

Even technically correct protocols can fail if users do not understand what they are committing to.

Mitigation Strategy

- Use simple onboarding language.
- Show required payment amounts and schedules clearly.
- Explain default consequences before joining.
- Use risk warnings.
- Avoid hiding complexity behind "one-click" UX.
- Provide clear user guide documentation.
- Avoid targeting financially vulnerable users before compliance and support infrastructure exist.

Recommended Public Framing

Use:

> RoundFi is being designed to make obligations, payments, and default consequences transparent.

Avoid:

> Anyone can use this to get easy credit.

---

17. Risk: Geographic and Jurisdictional Expansion

Description

RoundFi's market thesis includes LATAM and emerging markets, but credit, data, securities, VASP, and consumer protection rules vary by country.

Mitigation Strategy

- Do not launch globally by default.
- Start with a limited jurisdiction strategy.
- Prefer pilots with regulated partners.
- Avoid unsupported claims about legal availability.
- Maintain geo-specific risk analysis before production launch.
- Separate protocol development from regulated financial operations.

Recommended Public Framing

Use:

> RoundFi will pursue jurisdiction-specific compliance before production credit deployment.

Avoid:

> This can launch everywhere because it is on-chain.

---

18. Risk: Mainnet Readiness

Description

RoundFi has meaningful Devnet progress, but Devnet is not mainnet. Devnet proof shows execution capability, not production safety.

Requirements Before Mainnet

Before mainnet beta, RoundFi should have:

- external audit;
- complete production indexer;
- public documentation;
- mainnet risk parameters;
- insurance / reserve policy review;
- legal memo by target jurisdiction;
- partner pilot design;
- incident response plan;
- bug bounty;
- monitoring and alerting;

- rate limits and TVL caps;
- user disclosures.

Recommended Public Framing

Use:

> RoundFi has Devnet proof and is building toward a controlled mainnet beta.

Avoid:

> RoundFi is production-ready.

---

19. Compliance Roadmap

Phase 0 - Hackathon / Devnet

- Devnet prototype
- Open-source documentation
- Internal risk mapping
- No real-credit claims
- No mainnet user funds
- No legal availability claims

Phase 1 - Pre-Mainnet Review

- External legal review
- External security audit
- Privacy review
- Risk disclosures
- Jurisdiction strategy
- Protocol parameter review

Phase 2 - Controlled Mainnet Beta

- Caps on pool size
- Limited user cohort
- Partner integration sandbox
- Monitoring and incident response
- Bug bounty
- Conservative collateral rules

Phase 3 - B2B Reputation Oracle

- API access controls
- Explainable score methodology
- Data privacy framework
- Partner contracts

- Compliance reporting
- Score dispute and correction processes where applicable

---

20. What RoundFi Should Say Publicly

RoundFi should say:

- We are building a behavioral credit protocol on Solana.
- The current system is a prototype and Devnet validation layer.
- The reputation signal is generated through recurring financial participation.
- The protocol remained solvent within modeled stress conditions.
- Mainnet requires external audit and compliance review.
- The B2B oracle is the long-term product layer.
- Regulation and compliance are design constraints, not afterthoughts.

---

21. What RoundFi Should Not Say Publicly

RoundFi should not say:

- We are legally approved.
- The protocol cannot fail.
- Users are guaranteed loans.
- Yield is guaranteed.
- The system is risk-free.
- No regulation applies.
- The score will be accepted by every protocol.
- Mainnet is ready before audit.
- The project solves global financial inclusion immediately.
- RoundFi is a regulated consortium product unless that is legally confirmed.

---

22. Risk Matrix

Risk	Severity	Current Status	Mitigation
Credit / lending regulation	High	Roadmap concern	Legal counsel, partner-led pilots, avoid loan guarantees
Securities classification	High	Design concern	Avoid investment marketing, review NFTs/yield with counsel
VASP / AML exposure	High	Future operational concern	Modular compliance,

Risk	Severity	Current Status	Mitigation
			regulated partners, no unsupported claims
Privacy / data protection	High	Reputation-layer concern	Minimal on-chain data, no PII, consent and API controls
Smart contract bugs	High	Active technical risk	External audit, bug bounty, caps, CI, invariant tests
Economic model failure	High	Modeled only	Stress Lab transparency, parity tests, staged launch
Partner adoption	Medium-High	Roadmap	LOIs, pilots, API documentation, explainable scoring
Sybil / farming	Medium-High	Known reputation risk	Time/capital commitment, cooldowns, optional identity, analytics
Yield integration	Medium	Auxiliary layer	Zero-yield tests, adapter-is-untrusted, caps
SAS dependency	Medium	Architecture dependency	Modular schemas, fallback API/indexer, versioning
User misunderstanding	Medium	UX risk	Clear disclosures, user guide, simple onboarding
Geographic expansion	Medium	Roadmap	Jurisdiction-by-jurisdiction rollout

23. Conclusion

RoundFi's risks are real.

That is not a weakness.

It is the natural risk surface of any project trying to create a new credit primitive for DeFi.

The correct path is not to ignore those risks. The correct path is to structure the project so that each risk becomes a milestone:

- Devnet proof before mainnet;
- Stress Lab before real capital;
- internal audit before external audit;
- prototype before regulated deployment;
- reputation foundation before B2B oracle;
- partner pilots before broad launch;
- legal review before jurisdiction-specific credit products.

RoundFi's strongest risk posture is honesty:

> The protocol is ambitious, but its scope is being staged.
> The current product proves the mechanism.
> The next phase must prove security, compliance, and partner adoption.

This is the right path from hackathon prototype to credible financial infrastructure.

References

RoundFi Internal Documentation

- RoundFi README
- RoundFi Project Status Register (docs/status.md)
- RoundFi Devnet Deployment Record (docs/devnet-deployment.md)
- RoundFi Architecture Specification (docs/architecture.md)
- RoundFi Pitch Alignment (docs/pitch-alignment.md)
- RoundFi Yield Waterfall and Guarantee Fund (docs/yield-and-guarantee-fund.md)

External References

- Brazil Law 14.478/2022 - Virtual Assets Legal Framework: https://www.planalto.gov.br/ccivil_03/_Ato2019-2022/2022/Lei/L14478.htm
- CVM Guidance Opinion 40 - Cryptoassets and Securities Markets: https://www.gov.br/cvm/pt-br/assuntos/noticias/2022/cvm-divulga-parecer-de-orientacao-sobre-criptoativos-e-o-mercado-de-valores-mobiliarios
- FATF Targeted Updates on Virtual Assets and VASPs: https://www.fatf-gafi.org/en/publications/Fatfrecommendations/targeted-update-virtual-assets-vasps-2023.html
- European Union MiCA Regulation Summary: https://eur-lex.europa.eu/EN/legal-content/summary/european-crypto-assets-regulation-mica.html
- SEC BlockFi Settlement: https://www.sec.gov/newsroom/press-releases/2022-26
- European Commission - Personal Data under GDPR: https://commission.europa.eu/law/law-topic/data-protection/reform/what-personal-data_en

- ANPD - LGPD Frequently Asked Questions: https://www.gov.br/anpd/pt-br/acesso-a-informacao/perguntas-frequentes/perguntas-frequentes/1-lei-geral-de-protecao-de-dados-pessoais-lgpd/1-1-do-que-trata